

Année universitaire 2025-2026

MEMOIRE DE STAGE

Mise en place d'outils pour la supervision du réseau

MESULOG SAS



Mesulog

A Nerys Group Company

Présenté par

Vianney MIQUEL

Jury

IUT : M. FONTENAS

IUT : M. DUTOT

Société : M. DESRUELLE

Déclaration de respect des droits d'auteurs

Par la présente, je déclare être le seul auteur de ce rapport et assure qu'aucune autre ressource que celles indiquées n'ont été utilisées pour la réalisation de ce travail. Tout emprunt (citation ou référence) littéral ou non à des documents publiés ou inédits est référencé comme tel et tout usage à un outil doté d'IA a été mentionné et sera de ma responsabilité.

Je suis informé qu'en cas de flagrant délit de fraude, les sanctions prévues dans le règlement des études en cas de fraude aux examens par application du décret 92-657 du 13 juillet 1992 peuvent s'appliquer. Elles seront décidées par la commission disciplinaire de l'UGA.

À Moirans

Le 15/06/2026

Signature



Remerciements

Ce stage a été une expérience très positive, où j'ai pu me tester et acquérir de nouvelles compétences, aussi bien techniques que professionnelles. Je tiens donc à remercier toutes les personnes qui ont rendu cette expérience intéressante ; et pour leurs conseils, soutien et accompagnement je souhaite remercier :

- **Luc Desruelle** Mon maitre de stage qui m'a accueilli dans l'entreprise et m'a suivi tout au long de mon parcours. Il m'a permis de développer mes connaissances en aiguillant mes choix techniques
- **Benjamin Lerch** Développeur dans l'équipe Mesulog mais aussi responsable du service informatique, il a été d'une grande aide pour appréhender le système d'information de l'entreprise et m'a porté conseil en cas de problème.
- **Kenzo Sechi** Qui était aussi en alternance chez Mesulog, qui m'a aidé à m'intégrer dans l'équipe et a été d'une grande aide pour toute question.
- **Toute l'équipe Mesulog** Pour l'accueil à bras ouvert, qui m'a aidé à m'intégrer dans l'équipe. Pour leur aide et leurs conseils au long de mon stage.
- **Eric Fontenas** Mon tuteur pédagogique qui a répondu à toutes mes questions.
- **Pierre-françois Dutot** Qui a pris le temps de lire ce rapport afin de m'évaluer

Table des matières

1	Présentation du contexte professionnel	1
1.1	Présentation de l'entreprise	1
1.1.1	Présentation générale	1
1.1.2	Présentation du service d'accueil et de la hiérarchie Mesulog	2
1.1.3	Présentation de l'environnement technique	3
1.2	Objectifs et organisation des missions	3
2	Réalisation	3
2.1	Base de données Access	3
2.1.1	Nettoyage des données	5
2.1.2	Extraction des données pertinentes	6
2.2	Mise en place de Suricata	9
2.2.1	Configuration et intégration avec Wazuh	11
2.3	Installation et Intégration de Wazuh	13
2.3.1	Qu'est-ce que Wazuh	13
2.3.2	Les protocoles de Transmission de journaux	13
2.3.3	Architecture de Wazuh	14
2.3.4	Mise en place de Wazuh	15
2.3.4.1	Que faut-il mettre en place ?	15
2.3.5	Les décodeurs règles et alertes	16
2.3.5.1	Fonctionnement général	16
2.3.5.2	Decoders	17
2.3.5.3	Rules	17
2.3.6	Création de règles personnalisées	17
2.3.6.1	Travail réalisé	18
2.3.6.2	Alertes	18
2.3.7	Conclusion de la mission et critiques	19
2.4	Durcissement du système d'information à l'aide des standards CIS	20
2.4.0.1	Durcissement système	20
2.4.1	Les standards CIS	20
2.4.1.1	Alignement avec ISO 27001	20
2.4.2	Création d'un schéma structuré dans l'Active Directory	21
2.4.3	Stratégie de déploiement des GPO	22
2.4.4	Evolution de la conformité	23
2.4.5	Exemples concrets de GPO appliquées	24
2.4.6	Limitation du module SCA de Wazuh	25
2.4.6.1	Le problème de conformité	25
2.4.6.2	Solution	27
2.4.7	Conclusion de la mission et critiques	28
2.4.7.1	Axe d'amélioration possible - BloodHound	28
2.5	Création et implémentation d'une stratégie de sauvegarde	28
2.6	Entretien du parc informatique et missions annexes	28
3	Impact environnemental et sociétal	29
3.1	Impact de mes déplacements au long de mon alternance	29
3.1.1	Déplacements quotidiens	29
3.1.2	Déplacements ponctuels	29
3.2	Actions écologiques et sociales des actions menées par l'entreprise	29

3.3 Impacts sociétaux des projets réalisés	29
4 Bilan personnel	29
4.0.0.1 Références bibliographiques	31
Références	31

Table des figures

1	Présentation des sociétés filles de Nerys Group et de leurs directions	1
2	Présentation de la hiérarchie de l'équipe Mesulog	2
3	Chronologie des missions réalisées pendant mon stage	3
4	Schéma de la table initiale	4
5	Requête de normalisation des fins de numéro de série	5
6	Tableau récapitulatif général - (pour le banc VM-TD14-BHT)	6
7	Requête d'une table temporaire pour le calcul du TtFP (Time to First Pass)	7
8	Distribution des statuts de fin des essais par étape de l'essai, tous bancs confondus	8
9	Exemple de règle Suricata - ici une règle contre le mDNS poisoning	9
10	fichier Docker Compose	10
11	Interface web d'Evebox	11
12	Dashboard d'événements Docker dans Wazuh	12
16	Chaîne de traitement d'un log dans Wazuh	16
17	Exemple décodeur DHCP	17
18	Exemple de règles personnalisées pour vérifier la whitelist DHCP	18
19	Organisation initiale de l'Active Directory	21
20	Organisation de l'Active Directory après restructuration	21
21	Conformité du poste HP026 avant la première itération de déploiement des GPO	23
22	Évolution de la conformité CIS Level 1 du poste HP026 sur 4 itérations	24
23	Exemple d'un test SCA pour vérifier l'application d'une GPO	26
24	Commande gpupdate pour forcer la récupération des GPO sur le poste HP026 . . .	26
25	Rapport d'application des GPO sur le poste HP026	27
26	Rapport d'application des GPO sur le poste HP026	27
27	Commande PowerShell modifiée pour supporter les accents	28
13	Requêtes de nettoyage des données	32
14	Requêtes d'extraction de données	33
15	Distribution des statuts de fin des essais par étape de l'essai, modules V2	34

Introduction

Dans le cadre de mon BUT Informatique à l'IUT2, j'ai pu effectuer mon stage de fin de 3ème année dans l'entreprise Mesulog. Mesulog est une entreprise spécialisée dans les systèmes de test et mesures pour banc de tests. Cet environnement d'entreprise tourné vers l'industrie apporte des défis particuliers auxquels je dois me confronter.

Ce stage s'inscrit donc dans un processus de sécurisation du système d'information de l'entreprise, essentiel afin de garantir notamment la confidentialité de données industrielles confidentielles. La mise en place d'outils de supervision et de management d'événements de réseau et de sécurité a donc été mon sujet central au cours de ces 14 semaines.

Pour mieux comprendre les missions qui m'ont été confiées, il est important de présenter le contexte professionnel dans lequel j'ai évolué au cours de mon stage. la première partie de ce rapport est donc dédiée à la présentation de l'entreprise et du service d'accueil.

1 Présentation du contexte professionnel

1.1 Présentation de l'entreprise

1.1.1 Présentation générale

Mesulog est une entreprise basée à Moirans, en Isère. Elle est spécialisée dans le développement de logiciels : séquenceurs de test et outils de mesure; pour des bancs de test de produits, dans un domaine industriel. Avec de nombreuses certifications, Mesulog se place comme une entreprise spécialiste dans son domaine. C'est donc une PME avec des clients importants qui évoluent dans différents secteurs, allant de l'aéronautique à la recherche, en passant par l'industrie et l'automobile.

Mesulog fait aussi partie d'un groupe d'entreprise, **Nerys Group**. Nerys Group est la société mère qui regroupe Mesulog en Isère, Nerys dans les Bouches-du-Rhône et Territoire de Changements, ensuite devenue Nerys Group Service, en Savoie. Tandis que Mesulog est centrée autour du développement logiciel, Nerys est responsable de la conception de bancs de test, baies et coffrets électriques pour les environnements industriels. Nerys Group Service est quant à elle axée sur la proposition de formation dans les outils NI Labview et NI TestStand, logiciels utilisés pour la supervision des banc et séquencer les tests.

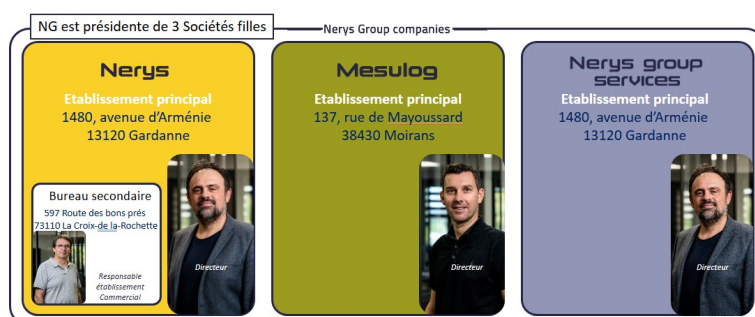


FIGURE 1 – Présentation des sociétés filles de Nerys Group et de leurs directions

1.1.2 Présentation du service d'accueil et de la hiérarchie Mesulog

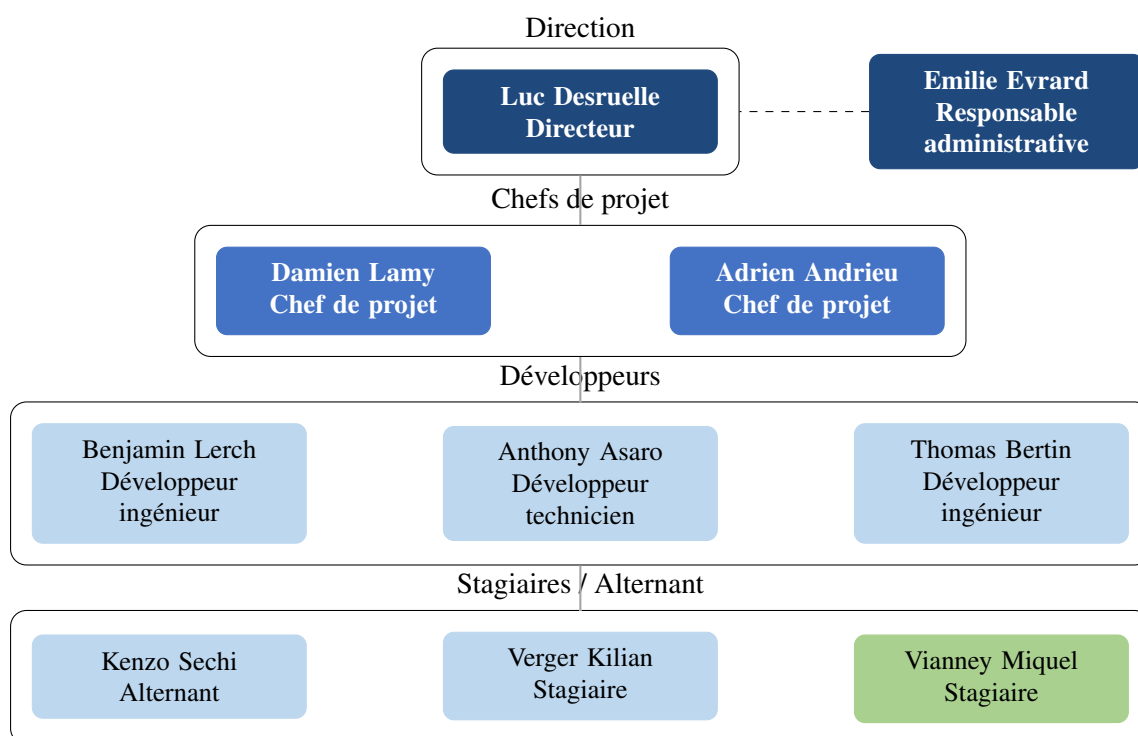


FIGURE 2 – Présentation de la hiérarchie de l'équipe Mesulog

Nous pouvons observer ci-dessus l'organigramme de l'équipe de Mesulog. L'équipe est composée de **Luc Desruelle**, qui est président de Nerys Group et assure le poste de directeur de Mesulog. Il est aussi le DSI de Mesulog.

Nous avons ensuite **Damien Lamy** et **Adrien Andrieu**, chefs de projet. Ils ont aussi des compétences de développeurs et présentent un profil technico-commercial. Le reste de l'équipe est composée de développeurs, à noter que Benjamin Lerch est également le RSSI du service informatique, il est donc mon supérieur direct.

Nous avons ensuite **Kenzo Sechi**, alternant en informatique, qui travaille avec moi. Le stagiaire **Kilian Verger** est un stagiaire en BUT mesures physiques.

Emilie Evrard est quant à elle la responsable administrative de Nerys Group. Les activités de comptabilité et de ressources humaines étant mutualisées entre les entreprises du groupe. Certains acteurs extérieurs à l'équipe de Mesulog travaillent de concert avec l'équipe, notamment des salariés de Nerys et Nerys Groups Service. Cependant ils ne sont pas représentés sur ce schéma organisationnel car je n'ai aucun contact avec eux dans mes missions.

Je suis donc entouré d'une équipe expérimentée qui peut m'apporter de l'aide et des conseils en cas de problème. J'ai aussi un contact direct avec mes supérieurs que ce soit Benjamin Lerch ou Luc Desruelle, mon maître de stage. Cela me permet de bénéficier d'un suivi régulier dans mes missions.

1.1.3 Présentation de l'environnement technique

[a faire presentation infrastructure réseau + logiciels utilisés]

1.2 Objectifs et organisation des missions

Durant mon stage, J'ai pu effectuer plusieurs missions, certaines étaient prévues à l'avance, d'autres sont apparues au fur et à mesure de l'avancement du stage. L'objectif initial de ce stage était la mise en place d'outils de supervision et de management d'événements de sécurité, tels que Suricata et Wazuh.

Cependant ce n'est pas la première mission que j'ai effectuée, en effet pour appréhender ce nouvel environnement j'ai commencé par une mission d'analyse et de mise en forme de données sur une base de données Access.

J'ai ensuite mis en place Suricata, un IDS open source, afin de surveiller les événements réseau. Suite à quoi j'ai installé et configuré le SIEM open-source Wazuh.

J'ai aussi pu retravailler l'organisation de l'Active Directory de l'entreprise, avec des mises en place de GPO, ou encore participé à la création d'une campagne interne de test de phishing. Certaines plus petites tâches se sont intercalées entre ces sujets principaux, elle ne seront pas détaillées dans ce rapport.

Ces missions étant toutes étroitement liées entre elles, excepté l'analyse de données pour un client, elles se sont déroulées en parallèles sur la durée de mon stage. par

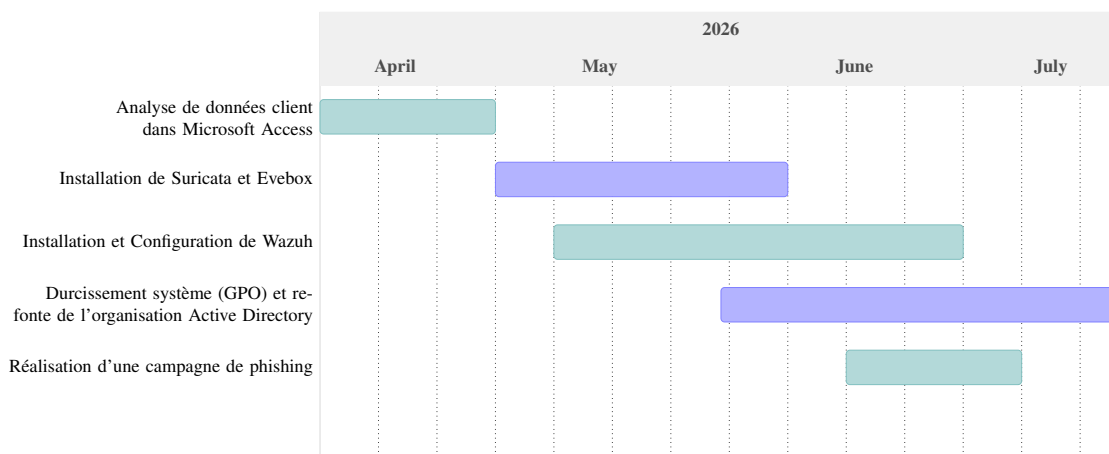


FIGURE 3 – Chronologie des missions réalisées pendant mon stage

2 Réalisation

2.1 Base de données Access

Au début de mon stage, j'ai travaillé sur une analyse de base de donnée Microsoft Access pour un client de Mesulog. Cette base de donnée, générée automatiquement depuis les rapports de test de banc de test Mesulog présent chez des clients, ce présente au départ comme 1 seule table à 23 colonnes.

Field Name	Data Type
StartTime	Date/Time
FolderStatus	Short Text
ReportFileName	Short Text
ReportPath	Short Text
UHF100name	Short Text
UUTresult	Short Text
StepCount	Number
StationID	Short Text
SerialNumber	Short Text
LoginName	Short Text
TotalTime	Short Text
Model	Short Text
Hardware	Short Text
PowerSupply	Short Text
DigitalInputVoltage	Short Text
PDTimerSynchronizationReferen	Short Text
UHFspectrumBandwith	Short Text
UHFspectrumResolution	Short Text
TimeAnalysisSamplingFrequency	Short Text
TimeAnalysisBandwith	Short Text
DallasSerialNumber	Short Text
MACaddress	Short Text
SoftwareVersion	Short Text
FirmwareVersion	Short Text

FIGURE 4 – Schéma de la table initiale

Il était donc courant d'avoir des enregistrements partiels, erronés ou avec un mauvais format. L'objectif final était de produire différents graphiques et tableaux pour analyser l'évolution de la production de modules, appelés "V1" ou "V2".

Les modules sont testés sur un banc, ils sont soit de type 1 ou 2. Un module passe un ou plusieurs tests ou essais avant d'être validé. Pour qu'un module soit validé il suffit d'un essai passé. Un essai à 4 issues : "Passed" (valide), "Failed" (non-valide), "Terminated" (le test s'est terminé prématurément) et "Error" (le banc de test a fait crasher le test).

Nous devons donc produire un tableau récapitulatif général par année et par banc avec entre autre les nombres de modules validés, le nombre d'essais moyen et médian avant pour un module avant d'être validé, le temps moyen en heure pour valider un module, le ratio des états des essais.

Le client a aussi 2 demandes plus particulières :

- Nous devons analyser plus précisément les états des essais les lundi matins car un nombre anormal d'erreurs sur le banc est suspecté.
- Nous devons aussi analyser la distribution des états des essais selon le pas de test. En effet une séquence d'essais complète comporte 39 étapes.

2.1.1 Nettoyage des données

Pour pouvoir correctement exploiter les données, il est important d'avoir des données complètes et sous le même format.

Les colonnes comportant des erreurs ou des oublis sont principalement :

- Le numéro de série du module, qui comporte parfois des espaces, lettres minuscule ou un mauvais nombre de caractères.
- Le type du module (V1 ou V2), qui est noté UHF100 pour V1, UHF100 V2 ou UHF1002Ghz. Cette valeur est souvent manquante, il faut donc l'inférer.
- Les essais qui font partis de la chaîne production et les essais de R&D ou de SAV qui ne sont pas signalés de manière consistante. Il faut écarter ces enregistrements de l'analyse.

Pour ce faire nous avons créé une suite de requêtes SQL pour automatiquement effectuer ce nettoyage. Etant donné que l'objectif final est d'automatiser l'exécution de toutes ces requêtes dans Microsoft Access avec un script VBS (Visual Basic Scripting), la syntaxe SQL utilisée est celle de Microsoft Access, qui nous impose des choix parfois sous-optimaux.

Pour ne pas surcharger ce rapport nous verrons ici seulement un exemple de formatage, le reste est disponible en Annexe [ici](#) :

```
1  --SETUP-09-SerialNumberNormalise-3
2
3  UPDATE RAW_DATA
4  SET
5      SerialNumberNormalise = IIf(
6          InStr (SerialNumberNormalise, ".") > 0,
7          Left (
8              SerialNumberNormalise,
9              InStr (SerialNumberNormalise, ".") -1
10         ) & "." & Right (
11             "000" & Mid (
12                 SerialNumberNormalise,
13                 InStr (SerialNumberNormalise, ".") + 1
14             ),
15             3
16         ),
17         SerialNumberNormalise
18     )
19 WHERE
20     InStr (SerialNumberNormalise, ".") > 0;
```

FIGURE 5 – Requête de normalisation des fins de numéro de série

Nous pouvons voir ci-dessus une requête destinée à formater tous les numéros de série sous la forme "*.XXX", "XXX" étant 3 chiffres.

Exemple : "17A240923.2" est transformé en "17A240923.002"

Afin de ne perdre aucune information, le numéro de série normalisé est inséré dans une nouvelle colonne. Il en va de même pour le modèle et pour l'objectif du test (Production ou SAV, R&D).

Une fois que toutes les données sont complétées et formatées, nous passons à l'exploitation de celles-ci.

2.1.2 Extraction des données pertinentes

L'objectif de cette partie est de remplir un tableau type comme présenté ci-dessous :

Banc 2 VM-TD14-BHT									
Année	2020	2021	2022	2023	2024	2025	2026	total	
Nb modules testés au Total	0	0	0	0	76	311	25	412	
Nb modules testés Production	0	0	0	0	75	310	20	405	405
Nb modules Prod validés	0	0	0	0	71	300	16	387	96 %
Nb modules Prod Non validés	0	0	0	0	4	10	4	18	4 %
Ratio module V2 sur total (%)					100,00 %	100,00 %	100,00 %		
Effort Pass (Moyenne)					3,65	2,73	3,44	3,3	
Effort Pass (Mediane)					2,00	2,00	3,00	2,3	
Time to First Pass (TtFP) en Heure					3,44	3,08	3,17		
Nb Essais Prod total					311	866	79	1256	31 %
Ratio Nb Essai Passed					23,47 %	34,76 %	18,99 %	25,74 %	
Ratio Nb Essai Failed					3,86 %	6,58 %	3,80 %	4,75 %	
Ratio Nb Essai Terminated					63,99 %	51,73 %	73,42 %	63,05 %	
Ratio Nb Essai Error					8,68 %	6,93 %	3,80 %	6,47 %	
Nb Essai Erreur Lundi 6h-10h					2	16	1	6,3	
Ratio Essai Erreur Lundi 6h-10h					10,00 %	17,39 %	12,50 %	13,30 %	
Nb Essai Erreur MMJV/4 6h-10h					2,75	4,00	0,00	2,3	
Ratio Essai Erreur MMJV/4 6h-10h					10,28 %	5,25 %	0,00 %	6,38 %	

FIGURE 6 – Tableau récapitulatif général - (pour le banc VM-TD14-BHT)

Ce tableau récapitulatif permet de voir facilement l'évolution de l'utilisation du banc, des résultats d'essais et du nombre de modules sortis en production.

Pour plus de précision, le "Effort to Pass" est le nombre d'essais avant une réussite, tandis que le "Time to First Pass" est le temps cumulé de tous les essais jusqu'à un essais validant.

Nous pouvons aussi voir des lignes mettant en évidence les différences d'essais en erreur entre les lundis matins et les autres jours de la semaine.

Dans ce jeu de données, nous avons 2 bancs est 2 types de modules. Il était demandé d'analyser l'évolution de la production par banc tous types de modules confondus et par banc seulement pour les modules types V2. Cela nous fait donc 6 tableaux à remplir de données.

Pour extraire ces données, nous partons de la table nettoyée, et nous avons fait une suite de 18 requêtes SQL pour extraire les données ou créer des tables temporaires pour d'autres requêtes. Si dans ces requêtes nous définissons le banc et le type de module en dur, il est prévu d'utiliser un script VBS (Visual Basic Scripting) pour remplacer automatiquement ces variables dans les requêtes.

Comme précédemment, nous ne montrons pas l'intégralité des requêtes dans le corps du rapport, mais elles sont disponibles en [Annexe](#).

```

1  --BC-MOD-15-TempTimediff
2
3  SELECT
4      SerialNumberNormalise,
5      Min(StartTime) AS FirstStart,
6      Min(IIf(Passed = True, StartTime, NULL)) AS FirstPass,
7      IIf(
8          Min(IIf(Passed = True, StartTime, NULL)) IS NULL,
9          NULL,
10         DateDiff(
11             "s",
12             Min(StartTime),
13             Min(IIf(Passed = True, StartTime, NULL))
14         )
15     ) AS DiffSeconds,
16     Min(IIf(Passed = True, TotalTime, NULL)) AS TestTimeSeconds,
17     Round(
18         (
19             (
20                 IIf(
21                     Min(IIf(Passed = True, StartTime, NULL)) IS NULL,
22                     NULL,
23                     DateDiff(
24                         "s",
25                         Min(StartTime),
26                         Min(IIf(Passed = True, StartTime, NULL))
27                     )
28                 ) + Min(IIf(Passed = True, TotalTime, NULL))
29             ) / 3600
30         ),
31         3
32     ) AS TimeToFirstPassHours
33 INTO
34     B1_temp_timediff
35 FROM
36     B1_table_essais_statut
37 GROUP BY
38     SerialNumberNormalise;

```

FIGURE 7 – Requête d’une table temporaire pour le calcul du TtFP (Time to First Pass)

Cette requête créer une table temporaire qui regroupe l’empreinte temporelle du premier essai d’un module, du premier essai validant, de la différence entre ces deux essais, du temps d’essai du second essai et finalement du "Time to First Pass" arrondi à l’heure.

Maintenant que nous avons extrait toutes les données nécessaires, nous pouvons les mettre en forme, voici donc quelques exemples de graphiques produits (L’ensemble est trouvable en [Annexe](#)) :

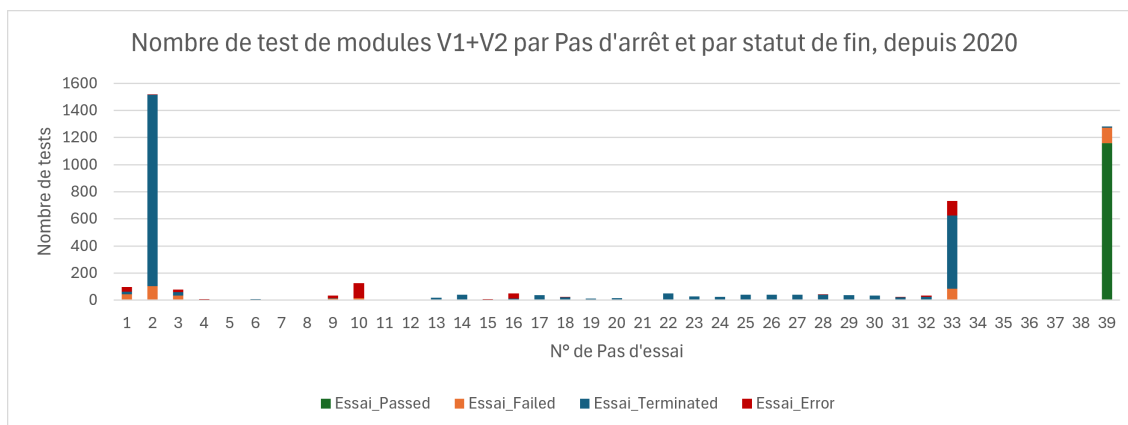


FIGURE 8 – Distribution des statuts de fin des essais par étape de l'essai, tous bancs confondus

2.2 Mise en place de Suricata

Suricata est un système de détection/prévention d'intrusion. Son fonctionnement est assez simple : il capture chaque paquet qui transite sur le réseau et analyse ses propriétés. Pour engendrer une alerte ou une action, Suricata utilise des règles, qui sont un ensemble de paramètres. Si une trame correspond à tous les critères (elle a la même signature) alors une action est prise par suricata.

```
1 alert udp any any -> any 546 (msg:"Suspicious DHCPv6 Advertise Packet  
   Detected, Possible attack using mitm6"; content:"|02|"; depth:1;  
   offset:0; reference:url,https://blog.exploit.org/caster-  
   neurotransmitter/; sid:1118750; rev:1;)
```

FIGURE 9 – Exemple de règle Suricata - ici une règle contre le mDNS poisoning

Suricata peut donc décider de ne rien faire, de générer une alerte ou de rejeter la trame en mode IPS (Intrusion Prevention System). En mode IDS (Intrusion Detection System) nous lançons simplement des alerts mais sans bloquer le trafic. C'est comme ça que nous l'installerons, afin d'éviter qu'un faux positif coupe une connexion légitime.

Pour installer Suricata, nous avons pris une machine physique. Pour éviter de risquer ralentir le trafic, nous avons mis en place un port mirroring à partir d'un switch juste en aval du pare-feu Sophos, le suricata reçoit donc une copie exacte de tout le trafic qui passe de WAN à LAN et de LAN à WAN.

La distribution linux utilisée en production à mesulog est Rocky Linux 10, une distribution RHEL (Red Hat). L'installation de suricata sur Rocky Linux se fait avec le dépôt COPR du projet OISF (développeurs et mainteneurs de Suricata).

Cependant ce dépôt qui installe via un fichier rpm n'arrive pas à résoudre ses dépendances sur Rocky 10. Nous avons donc choisi d'installer suricata via l'image docker fournie par Jason Ish, membre du projet OISF.

Ce choix technique nous permet aussi d'installer Evebox dans un second conteneur docker. Evebox est l'outil de gestion d'alerte et d'événement pour Suricata développé et maintenu lui aussi par le projet OISF. Ces 2 conteneurs sont réunis dans un même fichier docker compose pour une meilleure maintenabilité.

```

1 services:
2   suricata:
3     image: jasonish/suricata:latest
4     container_name: suricata
5     restart: always
6     network_mode: host
7     environment:
8       - TZ=Europe/Paris
9     cap_add:
10      - NET_ADMIN
11      - NET_RAW
12      - SYS_NICE
13     volumes:
14      - /var/log/suricata:/var/log/suricata
15      - /etc/suricata:/etc/suricata
16      - /var/lib/suricata/rules:/var/lib/suricata/rules
17     command:
18      - -i
19      - enp1s0
20      - -i
21      - enp2s0
22      - -c
23      - /etc/suricata/suricata.yaml
24   evebox:
25     image: jasonish/evebox:latest
26     container_name: evebox
27     restart: always
28     environment:
29       - TZ=Europe/Paris
30       - EVEBOX_RETENTION_PERIOD=168h
31     depends_on:
32       - suricata
33     ports:
34       - "5636:5636"
35     volumes:
36       - /var/log/suricata:/var/log/suricata
37     command:
38       - evebox
39       - server
40       - --host=0.0.0.0
41       - --port=5636
42       - --sqlite
43       - --input
44       - /var/log/suricata/eve.json

```

FIGURE 10 – fichier Docker Compose

Premièrement nous pouvons voir que les deux conteneurs sont paramétrés pour redémarrer automatiquement dès qu'ils sont éteints, pour limiter le temps hors-service. La variable d'environnement "TZ" permet de s'assurer que l'heure soit bien synchronisée dans les logs. Quelques points importants :

- Des capacités ont été ajoutées avec "cap_add" au conteneur Suricata pour accéder à l'interface réseau de la machine hôte, créer des sockets ou changer la priorité des processus si

besoin.

- La variable d'environnement "EVEBOX_RETENTION_PERIOD" permet de définir une limite de temps au delà de laquelle les logs sont effacés, très important pour ne pas saturer le stockage. Ici la limite est de 7 jours.

Ci-dessous l'interface web de Evebox, qui permet de suivre pas seulement les alertes mais tous les événements Suricata :

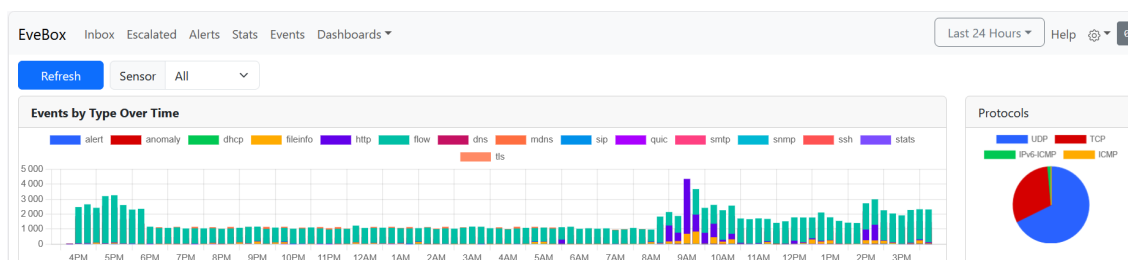


FIGURE 11 – Interface web d'Evebox

2.2.1 Configuration et integration avec Wazuh

Pour éviter de surcharger le SIEM, nous avons créé un deuxième fichier de log sous le format EVE (Extensible Event Format), intitulé eve-wazuh.json, dans lequel seulement les alertes Suricata sont loggées, contrairement au fichier de log eve.json pour Evebox où toutes les alertes ainsi que tous les événements sont loggés.

Ainsi nous avons un agent wazuh sur la machine hôte Rocky linux de suricata et evebox. Cet agent est configuré pour utiliser le fichier eve-wazuh.json comme source.

Cet agent wazuh a aussi une deuxième fonction ; en effet il vérifie régulièrement l'état des conteneurs dockers, et remonte des alertes dans wazuh dès qu'un changement d'état ou une commande docker est lancée sur la machine.

Il suffit par la suite de créer des règles dans Wazuh pour attraper les alerts suricata pertinentes.

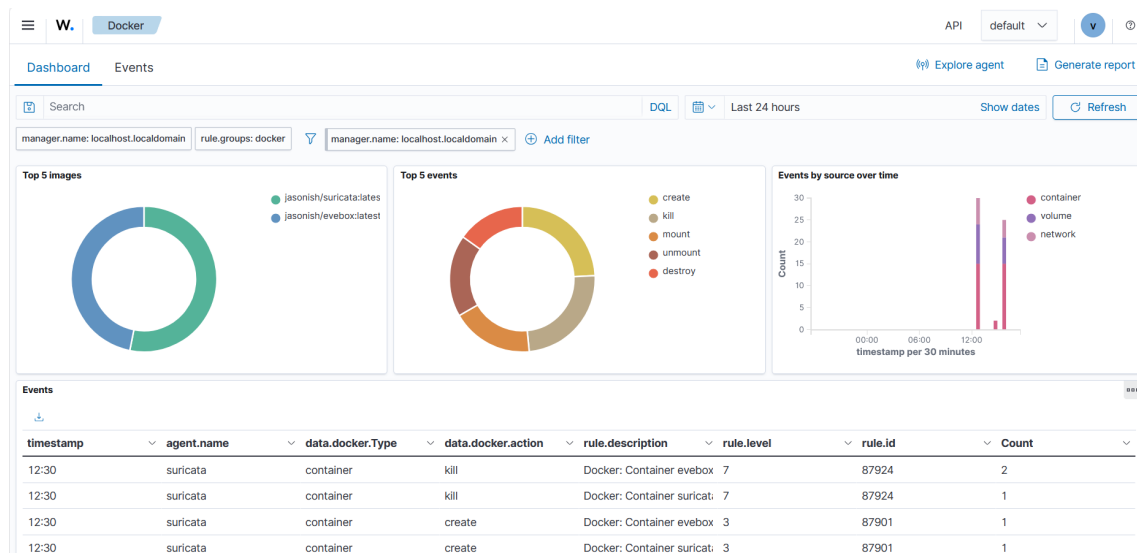


FIGURE 12 – Dashboard d'événements Docker dans Wazuh

En ce qui concerne les règles de Suricata en mode IDS, nous avons premièrement ajouté les règles de l'Open Emerging Threats publiées par Proofpoint. Avec des règles additionnelles, ajoutées à la suite de l'analyse de l'activité réseau avec Evebox.

Par exemple, en constatant un trafic significatif de packets mDNS sur le réseau, des règles contre le mDNS poisoning on été ajoutées dans un fichier de règle supplémentaire.

Afin de se prémunir contre les IPs malicieuses, nous avons ajouté des règles automatiquement suivant une liste d'ip malicieuse.

Pour ce faire, nous avons écrit un programme bash qui récupère des listes d'ip malicieuses depuis de listes de emerging threats, abuse.ch ou encore alien vault (Voir annexe). Nous concatenons ensuite ces liste dans un seul fichier, puis ajoutons pour chaque ip 2 règles dans un fichier de règle suricata "ip-reputation.rules"

une règle pour les connexions sortante et la deuxième pour les connexions entrantes depuis/vers cette ip. Ensuite le programme execute "docker kill --signal=USR2 suricata" qui envoie un signal non pas d'arrêt mais de reload des règles à chaud sans redémarrer le service.

Ce reload est d'ailleurs détecté par l'agent wazuh présent sur la machine hôte, qui remonte un événement de reload dans wazuh.

Pour executer ce programme de manière automatique, nous avons créé un service linux "suricata-ip-update.service" qui est lancé tous les jours à minuit par "suricata-ip-update.timer".

Grâce à l'option "RandomizedDelaySec=1800", ce timer a une fenêtre de 30 min (entre 00 :00 et 00 :30) pour lancer le service, ce qui permet d'éviter de surcharger la machine si des processus lousds sont déjà en train de s'exécuter (backup automatiques entre autre)

2.3 Installation et Intégration de Wazuh

Dans un système d'information (SI), il est primordial de surveiller les comportements utilisateurs et systèmes afin de prévenir de certaines pannes accidentelles, comportements inappropriés et attaques. La surveillance via divers outils comme les EDR, IDS/IPS et les Security Information and Event Management (SIEM) s'inscrit ainsi dans une démarche de sécurité et de sûreté vis-à-vis du SI, de ses utilisateurs ainsi que des différents actifs de l'entreprise qu'il est + important de protéger. De plus un SIEM peut également servir en tant que plateforme de journalisation, notamment dans un but de conformité aux standards ISO27001 (ex : A.8.15).

Cette surveillance se base ici sur Wazuh, un SIEM servant de point de centralisation de journaux des machines du parc.

2.3.1 Qu'est-ce que Wazuh

Wazuh est un SIEM, une plateforme permettant de centraliser, analyser enrichir et corrélérer les événements de sécurité afin de détecter des menaces. Il permet de surveiller une gamme d'équipements via le protocole Syslog ainsi que l'aide de ses agents. Les agents sont des logiciels installés sur les appareils administrés qui ont pour principal fonction de remonter les journaux systèmes ou applications des machines, ils peuvent également exécuter des commandes avec un privilège administrateur sur les machines ce qui peut s'avérer utile pour un outil de scan de permission par exemple mais dangereux dans le cas où une personne mal intentionnée arrive à prendre la main sur le serveur qui les déploie.

2.3.2 Les protocoles de Transmission de journaux

Le protocole Syslog est un protocole permettant l'échange de journaux système entre un serveur et un client dans un format centralisé défini selon les standards de la RFC 5424. Chaque champ est défini par cette norme et les valeurs stockées dedans également, à l'exception de certains champs laissés libres afin de permettre aux développeurs d'enrichir les logs de leur programme.

Le protocole est disponible en deux versions, TCP qui assure la transmission fiable des informations (port 514) et UDP (port 514) permettant un trafic plus important mais moins fiable.

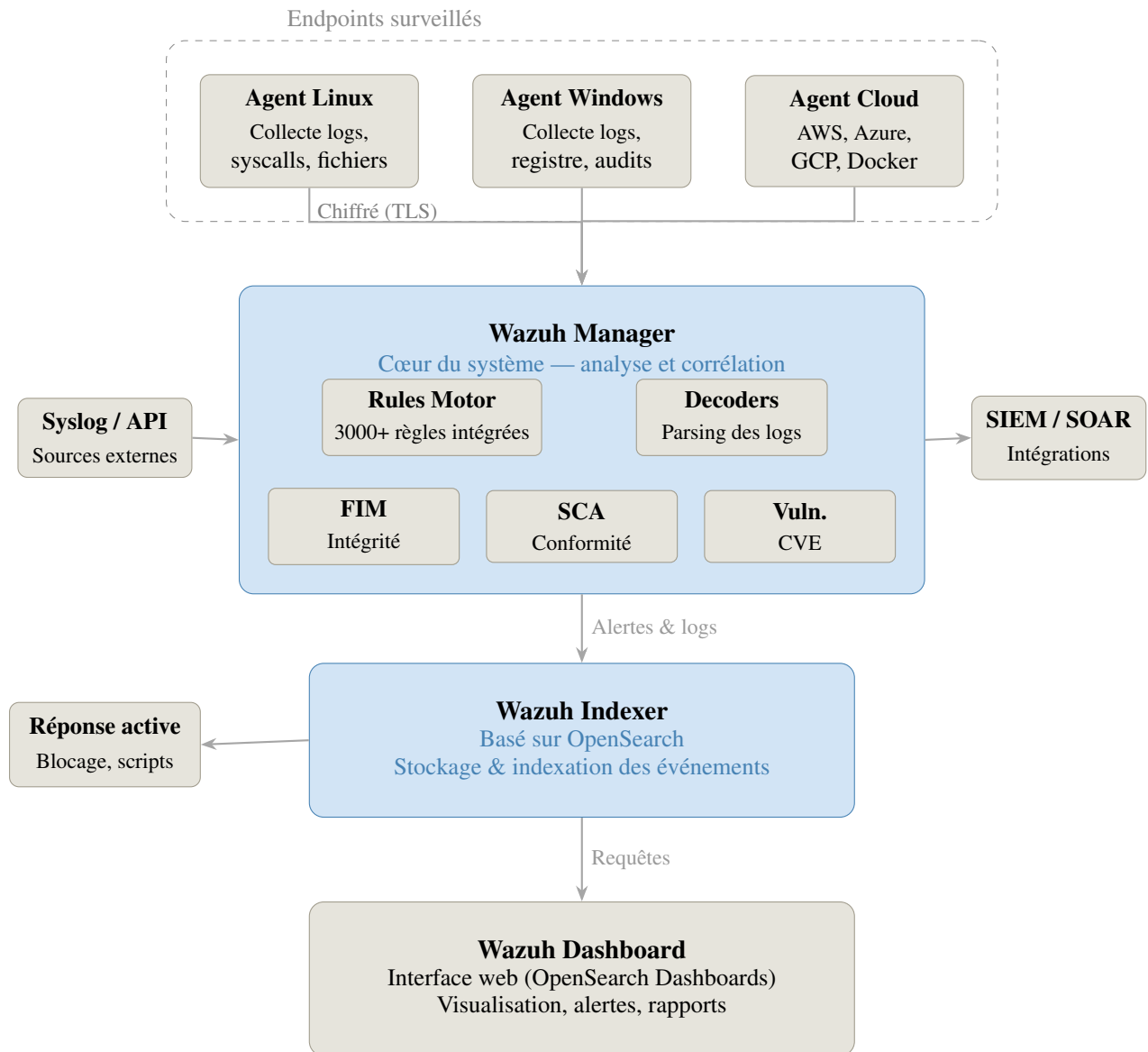
Exemple d'un Log :

Sep 14 14:09:09	machine_de_test	dhcp service	warning	110	corps du message
Date et heure	Hostname	Processus	Priorité	PID	Message

TABLE 1 – Structure d'un message Syslog

Outre Syslog, d'autres formats de journaux sont également utilisés dans les systèmes d'information. Parmi eux, le format CEF (Common Event Format), développé par ArcSight, permet de standardiser les événements de sécurité provenant d'équipements et de logiciels différents. Son format structuré facilite leur collecte, leur analyse et leur corrélation au sein d'un SIEM.

2.3.3 Architecture de Wazuh



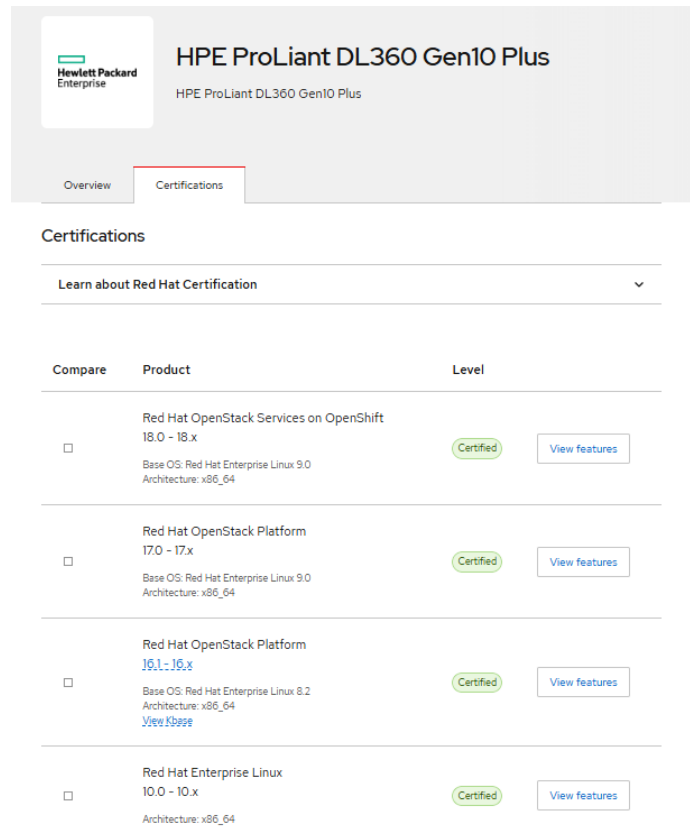
Comme on peut le voir sur ce schéma, Wazuh se compose de trois éléments principaux :

- les agents, qui collectent les données de sécurité à partir des systèmes surveillés et les transmettent au Manager via le protocole Syslog TCP ou d'autres méthodes de communication.
- le Manager, qui est le cœur du système, chargé de collecter, analyser et corréler les journaux envoyés par les agents.
- l'Indexer, basé sur OpenSearch, qui stocke et indexe les données pour permettre des recherches rapides et efficaces.
- le Dashboard, qui offre une interface web pour visualiser les alertes, générer des rapports, interagir avec les données collectées et configurer l'outil.

2.3.4 Mise en place de Wazuh

2.3.4.1 Que faut-il mettre en place ?

La mise en place de Wazuh a été réalisée sur un serveur Rocky Linux 10 (RHEL 10) virtualisé sur un hyperviseur HyperV ; HPE ProLiant DL360 Gen10 Plus. Le choix de ce système d'exploitation s'explique par sa stabilité ainsi que l'assurance de son support à long terme (10 ans) ce qui est un critère important pour une entreprise, de plus, RedHat assure une compatibilité totale matérielle avec les serveurs HPE via le grade "Certified" consultable sur le site web de l'entreprise ce qui n'est pas forcément proposé par d'autres Systèmes d'exploitation.



The screenshot shows the 'Certifications' tab for the HPE ProLiant DL360 Gen10 Plus. It features a table with four rows of Red Hat certifications. Each row includes a checkbox, the product name, version, base OS, architecture, a 'Certified' badge, and a 'View features' button.

Compare	Product	Level
☐	Red Hat OpenStack Services on OpenShift 18.0 - 18.x Base OS: Red Hat Enterprise Linux 9.0 Architecture: x86_64	Certified View features
☐	Red Hat OpenStack Platform 17.0 - 17.x Base OS: Red Hat Enterprise Linux 9.0 Architecture: x86_64	Certified View features
☐	Red Hat OpenStack Platform 16.1-16.x Base OS: Red Hat Enterprise Linux 8.2 Architecture: x86_64 View KB page	Certified View features
☐	Red Hat Enterprise Linux 10.0 - 10.x Architecture: x86_64	Certified View features

Le processus d'installation de Wazuh s'est déroulé en trois étapes principales :

- La Création d'une VM HyperV ayant les paramètres adaptés (stockage, cpu, ram etc.)
- L'installation des différents composants (Wazuh Manager, Wazuh Indexer et Wazuh Dashboard) sur la VM
- L'ajout d'un enregistrements DNS afin de rendre la configuration plus maintenable

Je n'ai pas eu besoin de réinstaller les agents sur les ordinateurs mais seulement de modifier l'adresse de wazuh vers son nom **ex : 192.168.1.12 → wazuh.mesulog.local**

Le processus d'installation est disponible dans l'Annexe [créer et référencer l'annexe]

2.3.5 Les décodeurs règles et alertes

2.3.5.1 Fonctionnement général

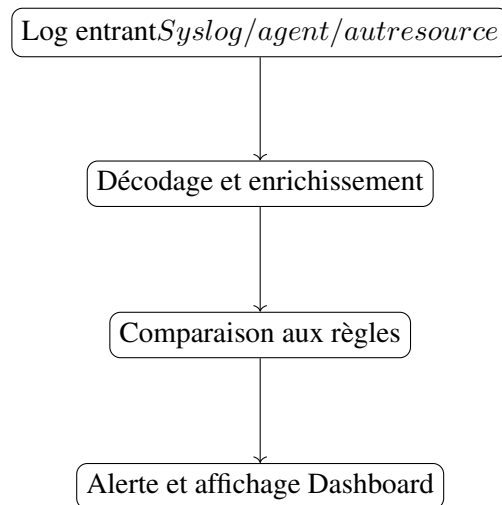


FIGURE 16 – Chaîne de traitement d'un log dans Wazuh

Ce schéma présente le processus de gestion de l'arrivée d'un log dans Wazuh Manager jusqu'à la montée d'alerte traité par un administrateur système / Analyste SOC :

- D'abord le log arrive sur un des ports ouverts de Wazuh Manager (514 Syslog UDP, 1515 agent etc.)
- Le Log est ensuite parsé dans un décodeur, cette étape peut se répéter plusieurs fois si à la sortie de ce décodeur le résultat match avec un autre décodeur
- Le résultat est ensuite comparé avec les différentes règles incluses dans Wazuh ainsi qu'avec les règles custom, si une correspondance est avérée, une règle sera relevée et elle apparaîtra dans le Dashboard Wazuh (si elle est supérieure à 0)
- Il est alors possible de créer des alertes en fonction du niveau de chaque règle levée, ces alertes peuvent être envoyées via différents canaux (mail, teams, slack)

2.3.5.2 Decoders

Les décodeurs représentent la première couche de traitement de logs dans wazuh, il en existe 2 sortes :

- les natifs, présents sous `/var/ossec/ruleset/decoder/0XXX-Nom`
- les customs, présents sous `/var/ossec/etc/decoder/Nom`

Les décodeurs custom ont plusieurs fonctions, ils permettent notamment d'interpréter des logs provenant de sources pour lesquelles wazuh ne propose pas de décodeur intégré, ou de surcharger certains décodeurs existant afin d'enrichir le log. Voici un exemple de décodeur :

```
1 <decoder name="ms-dhcp-ipv4">
2   <prematch>^\d\d,\d+/\d+/\d\d\d\d,\d+:\d+:\d+,|</prematch>
3   <prematch>^\d\d,\d+/\d+/\d\d,\d+:\d+:\d+,</prematch>
4   <regex>^(\d\d),\d+/\d+/\d\d\d\d*,\d+:\d+:\d+,(\w+),(\S+)</regex>
5   <order>id,extra_data,srcip</order>
6 </decoder>
```

FIGURE 17 – Exemple décodeur DHCP

Ce décodeur permet d'analyser les journaux générés par le service DHCP de Windows. Les expressions régulières permettent d'extraire automatiquement plusieurs informations du log, telles que l'identifiant de l'événement, les données complémentaires et l'adresse IP source, qui pourront ensuite être exploitées par les règles de détection de Wazuh. Les champs extraits sont ensuite stockés dans des variables Wazuh (id, extra_data, srcip). Voici les champs extraits par ce décodeur :

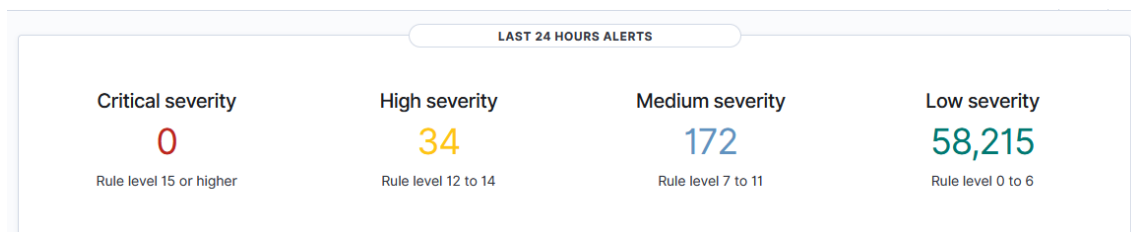
24	DNS Update Request	201.10.168.192
id	extra_data	srcip

TABLE 2 – Champs extraits par le décodeur DHCP

Après application du décodeur, ces variables sont utilisées pour la création de règles personnalisées ou pour l'affichage d'alertes plus détaillées dans le dashboard Wazuh.

2.3.5.3 Rules

Les règles sont déclenchés en fonction des logs décodés lorsqu'un log correspond à leurs critères, leurs champ *level* permettent d'attribuer une criticité de 0 à 15, le détail sur la criticité est expliqué dans le tableau suivant qui apparaît sur la page d'accueil Wazuh.



2.3.6 Création de règles personnalisées

Les règles personnalisées permettent de créer des alertes spécifiques en fonction des besoins de l'entreprise. Elles suivent globalement le même fonctionnement que les décodeurs, elles sont

composées d'une partie de pré-matching qui permet de filtrer les logs à traiter, d'une partie de matching qui permet d'extraire des champs du log et d'une partie de description qui permet de définir le message d'alerte qui sera affiché dans le dashboard Wazuh.

Il est possible pour une règle de faire référence à une autre règle via la balise `if_sid`, ce qui permet de faire du chaining de règles, c'est à dire que si une règle est levée, elle peut faire référence à une autre règle qui elle même peut faire référence à une autre règle etc.

2.3.6.1 Travail réalisé

Plusieurs règles personnalisées ont été créées, l'objectif principale était de détecter la présence de nouveaux appareils sur le réseau LAN ou sur le réseau wifi (invité) de l'entreprise.

Pour ce faire, j'ai créé 2 règles permettant de vérifier les baux DHCP renouvelés sur le réseau wifi invité de l'entreprise ainsi que 2 règles permettant de vérifier les baux DHCP renouvelés sur le réseau LAN de l'entreprise. L'objectif était de détecter les appareils connus et inconnus se connectant au réseau, en utilisant une liste blanche d'adresses MAC autorisées définie sur le serveur Wazuh. Voici les exemple de règles personnalisées créées pour cette surveillance :

```
1 <group name="dhcp">
2   <rule id="120052" level="3">
3     <if_sid>6305</if_sid>
4     <list field="mac" lookup="match_key">etc/lists/known-devices</list>
5     <description>DHCP lease renewed for $(mac) = $(srcip)</description>
6   </rule>
7   <rule id="120053" level="12">
8     <if_sid>6305</if_sid>
9     <list field="mac" lookup="not_match_key">etc/lists/known-devices</list>
10    <description>ALERT! Unknown device connected: for $(mac) = $(srcip)
11  </description>
12  </rule>
13 </group>
```

FIGURE 18 – Exemple de règles personnalisées pour vérifier la whitelist DHCP

Ci-dessus, deux règles personnalisées ont été créées pour vérifier les baux DHCP renouvelés sur le wifi invité de la société. La première règle (ID 120052) est déclenchée lorsque le champ "mac" du log correspond à une adresse MAC présente dans la liste "known-devices", indiquant qu'un appareil connu a renouvelé son bail DHCP. La seconde règle (ID 120053) est déclenchée lorsque le champ "mac" ne correspond pas à une adresse MAC de la liste, signalant la connexion d'un appareil inconnu et générant une alerte critique.

2.3.6.2 Alertes

Les alertes constituent une fonction centrale du SIEM, permettre d'alerter les équipes de sécurité en cas d'événements suspects ou critiques détectés. Elles peuvent être configurées pour être envoyées via différents canaux de communication, tels que les emails, les notifications sur des plateformes de collaboration (Teams, Slack) ou même des intégrations avec des systèmes de ticketing

comme GLPI ou Jira.

** présenter la montée d'alertes ainsi que les artes perso définies

2.3.7 Conclusion de la mission et critiques

2.4 Durcissement du système d'information à l'aide des standards CIS

L'une de mes missions principales a été de contribuer au durcissement du système d'information de l'entreprise en appliquant les recommandations du Center for Internet Security (CIS).

2.4.0.1 Durcissement système

Le durcissement système est un ensemble de procédés de restriction des droits visant à réduire la surface d'attaque possible sur un système informatique, cette mission se concentre sur le durcissement d'ordinateurs Windows 11 via les Group Policy Objects (GPO) mais le procédé de durcissement existe également sur les systèmes Linux. Il y a plusieurs façon de durcir des systèmes comme l'installation d'une image préconfiguré pour être durcie ou bien l'application de GPO suivant des standards prédéfinis.

2.4.1 Les standards CIS

Plusieurs standards sont disponibles afin de durcir les systèmes windows, notamment :

- Microsoft Security Baselines
- CIS Benchmarks
- NIST Cybersecurity Framework
- STIGs (Security Technical Implementation Guides)

Le CIS propose des benchmarks de sécurité pour différents systèmes d'exploitation, applications et configurations, visant à réduire les vulnérabilités et à renforcer la résilience face aux attaques. Ces benchmarks sont organisés en 2 niveaux :

- le Level 1 représente les configurations de sécurité essentielles et facilement déployables
- le Level 2 inclut des mesures plus restrictives adaptées aux environnements hautement sécurisés.

Après évaluation des différents standards disponibles, nous avons décidé d'appliquer les standards CIS Level 1 sur l'ensemble de notre parc informatique. Ce choix a été motivé par le fait que les benchmarks CIS Level 1 sont déjà présents et intégrés dans le module Security Configuration Assessment (SCA) de Wazuh, permettant ainsi une détection et une validation automatisées des configurations de sécurité sans nécessiter des outils supplémentaires.

2.4.1.1 Alignement avec ISO 27001

L'application des recommandations CIS Level 1 s'aligne naturellement avec les exigences de la norme ISO 27001. En effet, les baselines CIS contribuent au traitement des risques et à la mise en œuvre de mesures techniques et organisationnelles correspondant aux contrôles d'Annexe A par exemple la gestion des accès, exploitation sécurisée et protection des actifs (A.9, A.12, A.8). Cette approche facilite la démonstration de conformité lors d'un audit ISO 27001 en fournissant des preuves de configuration, de surveillance et d'amélioration continue des contrôles de sécurité.

2.4.2 Création d'un schéma structuré dans l'Active Directory

Avant de déployer les configurations, la première étape était de créer un schéma structuré dans l'Active Directory (AD) afin de mieux hiérarchiser les comptes utilisateurs ainsi que les ordinateurs et serveurs présents sur le domaine. Cette structuration permet de faciliter la gestion des permissions, d'améliorer la visibilité sur les ressources et de renforcer la sécurité en limitant les accès aux ressources sensibles par le principe du moindre privilège.

Voici le schéma Active Directory initialement mis en place :

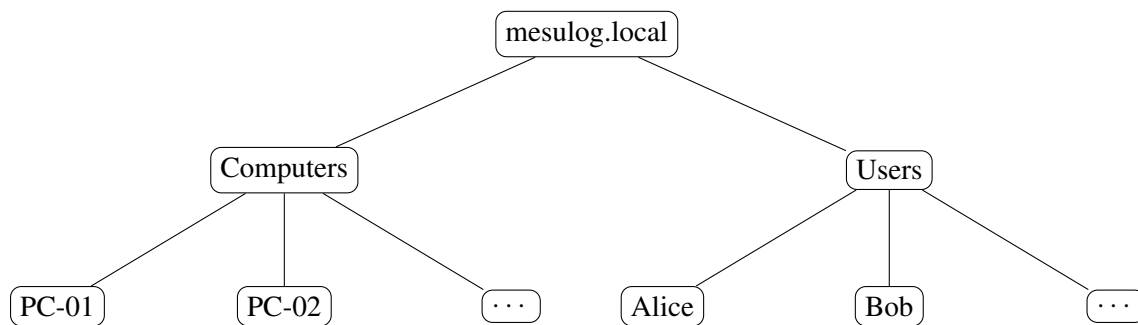


FIGURE 19 – Organisation initiale de l'Active Directory

Bien que ce schéma minimale soit fonctionnel, il ne permet pas de gérer efficacement les ressources et les permissions, il présente les défauts suivants :

- Absence d'Unités d'Organisation (OU) pour regrouper les ressources par fonction, département ou niveau de sensibilité.
- Manque de groupes de sécurité pour attribuer des permissions de manière centralisée et éviter les permissions directes sur les comptes utilisateurs ou ordinateurs.
- Difficulté à appliquer des stratégies de groupe (GPO) spécifiques à certaines catégories d'utilisateurs ou d'ordinateurs en raison de l'absence de hiérarchie claire.

Afin de pallier à ces problèmes, il a été proposé et mis en place une nouvelle organisation de l'Active Directory, structurée autour de plusieurs OU et groupes de sécurité. Cette nouvelle organisation permet une gestion plus efficace des ressources, une meilleure application des politiques de sécurité et une réduction des risques liés à des permissions mal configurées. Voici le schéma de l'Active Directory après restructuration :

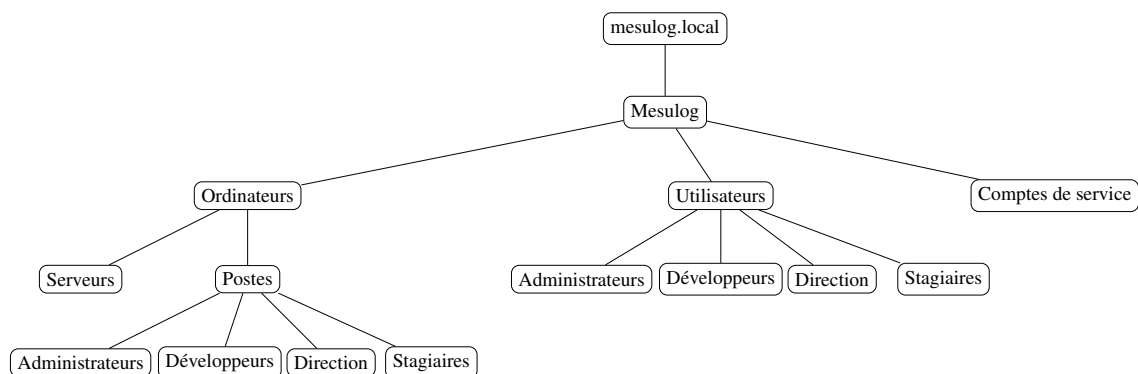


FIGURE 20 – Organisation de l'Active Directory après restructuration

Le schéma ci-dessus représente l'organisation finale de l'Active Directory, son découpage est le suivant :

- **Ordinateurs** composé de l'OU **Postes** réparties entre les **Administrateurs, Développeurs, Direction** et **Stagiaires** ainsi que de l'OU **Serveurs**
- **Utilisateurs** composé des différents utilisateurs du domaine également répartie entre les **Administrateurs, Développeurs, Direction** et **Stagiaires**
- **Comptes de services** composé des comptes utilisés par certains serveurs pour accéder à différentes machines et serveurs présents sur le domaine, le but est d'éviter d'utiliser un seul compte qui aurait trop de droits sur l'ensemble du domaine en définissant un compte par utilisation (e.g. compte de sauvegarde)

Ce découpage permet de mieux hiérarchiser les droits selon les personnes dans l'entreprise, les développeurs bénéficient par exemple de plusieurs droits relatifs à la virtualisation afin de développer dans des machines virtuelles, les autres fonctions de l'entreprises comme la Direction qui ne s'occupe que de document légaux et organisationnelle ne bénéficient pas de ces droits car inutiles dans leurs cas.

2.4.3 Stratégie de déploiement des GPO

Afin de déployer les GPO de durcissement, il a été décidé de suivre une approche progressive, tout d'abord, l'ensemble des GPO recommandées ont été réparties dans un classeur excel en fonction de :

- leur nom
- leur description
- le numéro de la recommandation CIS correspondante
- leur impact potentiel sur les utilisateurs et les systèmes
- leur criticité, niveau de sécurité (faible, moyenne, élevée)
- leur pertinence par rapport aux besoins et au contexte de l'entreprise
- leur catégorie (gestion des comptes, sécurité réseau, protection des données, etc.)
- leur statut (À tester, Déployée, Exclue)

Cette classification a permis après une revue par l'ensemble de la DSI (Administrateurs Systèmes et RSSI) de prioriser les GPO les plus importantes avant de les déployer.

Le déploiement a lui été réparties en plusieurs itérations successives espacées dans le temps de plusieurs jours entre chaque, le but était de comprendre au plus vite si une GPO ne fonctionnait pas par rapport à un cas d'utilisation non prévu lors de l'évaluation préliminaire.

Une convention de nommage fut également établie afin de faciliter la gestion et la maintenances des GPO, par exemple, la stratégie *IT1* - Paramétrage des stratégies d'audits* est répartie selon les champs suivants :

Champ	Description
IT1	Numéro de l'itération durant laquelle la GPO a été créée ou déployée.
*	Indique que plusieurs GPO participent à une même fonctionnalité et sont regroupées logiquement.
Paramétrage des stratégies d'audit	Description concise de l'objectif ou du contenu de la GPO. Les termes utilisés peuvent être « Paramétrage », « Activation », « Désactivation », etc. selon la nature de la configuration appliquée.

TABLE 3 – Convention de nommage des GPO

2.4.4 Evolution de la conformité

Tous les tests de conformités ont été réalisés à l'aide du module SCA de Wazuh sur le PC HP026 situé dans l'OU "Postes\Administrateurs" qui est un poste de travail utilisé par les administrateurs systèmes de l'entreprise.

À ce moment, les 4 premières itérations viennent d'être effectuées, le processus de choix et de revue étant particulièrement long, il se peut que l'on ne puisse avoisiner les 100% de conformité avant la fin de l'alternance, cependant, l'objectif est d'atteindre au moins 70% de conformité sur ce poste. Ci-dessous se trouve la capture d'écran de Wazuh montrant le niveau de conformité du poste HP026 avant le début du déploiement des GPO :

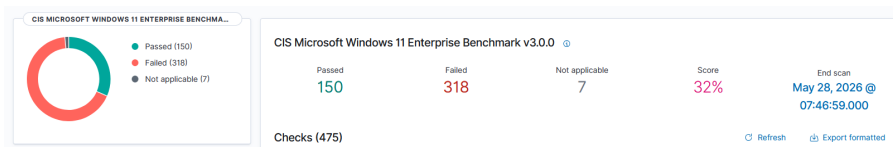


FIGURE 21 – Conformité du poste HP026 avant la première itération de déploiement des GPO

On observe que la conformité est faible, seulement 32%, ce qui montre l'importance de cette mission de durcissement du système d'information.

Afin de visualiser la progression obtenue au fil des itérations, le graphique ci-dessous présente l'évolution du taux de conformité aux standards CIS Level 1 pour le poste HP026, depuis l'état initial jusqu'à la quatrième itération de déploiement des GPO.

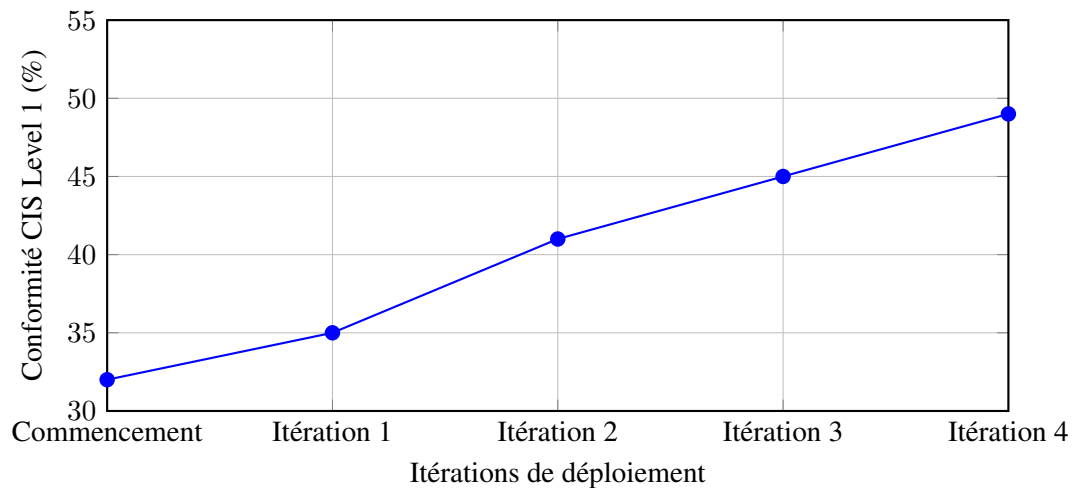


FIGURE 22 – Évolution de la conformité CIS Level 1 du poste HP026 sur 4 itérations

Après l'itération 4, le taux de conformité a atteint 49%, ce qui représente une amélioration significative par rapport à l'état initial de 32%. Il reste cependant une marge de progression afin d'atteindre l'objectif de 70% de conformité, ce qui nécessitera la poursuite du déploiement des GPO et l'ajustement des configurations en fonction des résultats obtenus lors des prochaines itérations.

2.4.5 Exemples concrets de GPO appliquées

Viser un objectif de conformité est intéressant seulement si on donne du sens à cet objectif, il est important de comprendre les différentes attaques ou vulnérabilités que l'on cherche à traiter en appliquant ces GPO, voici quelques exemples concrets de GPO appliquées et des attaques ou vulnérabilités qu'elles permettent de traiter :

N° CIS	Nom	Objectif technique	Risque traité / Impact
26303	Désactiver l'exécution automatique des médias	Empêcher l'exécution automatique de code depuis supports amovibles (CD, USB, etc.).	Empêche l'exécution de payloads malveillants déposés sur des médias amovibles (auto-run/autoplay). Faible impact pour postes standards, peut gêner certains usages nomades. Déployé en pilote.
26028	Désactiver le cache des ouvertures de session précédentes	Ne pas stocker localement les informations des sessions précédentes (cache d'identifiants/jetons).	Réduit l'impact en cas de vol ou compromission d'un poste (réutilisation de sessions/cookies). Moyennement contraignant pour utilisateurs nomades; à tester avant déploiement large.
26193	Désactiver le protocole LLMNR	Désactiver LLMNR/mDNS sur les interfaces afin d'empêcher la résolution de noms non sécurisée.	Évite les attaques de type LLMNR/NBT-NS poisoning permettant le détournement de trafic et le vol d'identifiants. Recommandé en environnement d'entreprise; faible impact fonctionnel si DNS interne est bien configuré.

TABLE 4 – Exemples concrets de GPO appliquées et des risques associés

2.4.6 Limitation du module SCA de Wazuh

Bien que pratique, le module SCA de Wazuh n'en reste pas moins limité, voici comment il fonctionne :

1. Pour chaque ordinateur / Serveur, un fichier *.xml* avec des commandes pour tester l'application des GPO est envoyé dessus
2. Ces commandes présentes dans le fichier sont ensuite exécutées par un script sur les machines
3. Le résultat de ce script est ensuite envoyé à Wazuh Manager afin d'être traité et de calculer le taux de conformité.

2.4.6.1 Le problème de conformité

Nous avons constaté après l'application de plusieurs GPO que le taux de conformité n'augmentait pas malgré le fait que les GPO soient appliquées sur les machines, après investigation, il s'est avéré que le module SCA ne prenait pas en compte certaines configurations appliquées par les GPO, ce qui faussait le taux de conformité affiché dans Wazuh.

En ouvrant le fichier *xml* envoyé par Wazuh sur les machines nous avons constaté que quand le module SCA testait l'application d'une GPO, il vérifiait la configuration d'une clé de registre spécifique, cependant, certaines GPO appliquaient des configurations qui n'étaient pas liées à des

clés de registre, pour ces dernières, le module test directement de la conformité d'un paramètre via une commande PowerShell, voici un exemple concret :

```
1 - id: 26145
2 title: "Ensure 'Audit Credential Validation' is set to 'Success and
   Failure'."
3 description: "This subcategory reports the results of validation
4 tests on credentials submitted for a user account logon request.
   "
5 rationale: "Auditing these events may be useful when investigating
6 a security incident."
7 remediation: "To establish the recommended configuration via GP,
   [...] Validation"
8 compliance:
9   - cis: ["17.1.1"]
10  - cis_csc: ["8.5"]
11 condition: all
12 rules:
13   - 'c:auditpol.exe /get /subcategory:"Credential Validation"
14     -> r:Success and Failure'
```

FIGURE 23 – Exemple d'un test SCA pour vérifier l'application d'une GPO

L'extrait ci-dessus représente un des tests présent dans le fichier *xml* utilisé pour les tests de conformité Windows 11, il est utilisé pour vérifier que la stratégie d'audit "Audit Credential Validation" servant à créer des journaux d'audit lors de la validation des identifiants est bien configuré pour auditer à la fois les succès et les échecs.

Le champ *rules* contient la commande exécuté après la chaîne *c* : et le résultat attendu après la chaîne *r* : , si le résultat de la commande correspond au résultat attendu, alors le test est considéré comme réussi, sinon, il est considéré comme échoué.

Lors de la deuxième itération, après le déploiement des GPO, nous avons constaté que le taux de conformité n'augmentait pas malgré le fait que les GPO soient appliquées, Curieux, nous avons d'abord vérifié que les ordinateurs récupéraient bien les nouvelles GPO :

```
PS C:\WINDOWS\system32> # Recuperation forcee des GPO sur le domaine
PS C:\WINDOWS\system32> gpupdate /force
Mise à jour de la stratégie...

La mise à jour de la stratégie d'ordinateur s'est terminée sans erreur.
La mise à jour de la stratégie utilisateur s'est terminée sans erreur.

PS C:\WINDOWS\system32>
PS C:\WINDOWS\system32> # Generation de rapport sur application des GPO sur le poste HP026
PS C:\WINDOWS\system32> gpresult /H "C:\DATA\rapport.html"
```

FIGURE 24 – Commande gpupdate pour forcer la récupération des GPO sur le poste HP026

Une fois le rapport généré, nous avons constaté que les GPO étaient bien actives sur le poste :

Computer Configuration (Enabled)	
Policies	
Windows Settings	
Security Settings	
Local Policies/User Rights Assignment	
Local Policies/Security Options	
Devices	
Policy	Setting
Devices: Restrict CD-ROM access to locally logged-on user only	Disabled
Devices: Restrict floppy access to locally logged-on user only	Disabled
User Account Control	
Policy	Setting
User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode	Elevate without prompting
Registry Values	
Policy	Setting
MACHINE\Software\Microsoft\Driver Signing\Policy	1
MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoDriveTypeAutoRun	255
MACHINE\System\CurrentControlSet\Control\Lsa\FIPSAlgorithmPolicy	1
MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\SynAttackProtect	1
MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\TCPMaxPortsExhausted	5

FIGURE 25 – Rapport d'application des GPO sur le poste HP026

Les GPO attendus apparaissant dans le rapport, nous avons donc décidé de vérifier directement les commandes utilisées par le module SCA pour tester la conformité des GPO :

```
PS C:\WINDOWS\system32> # Commande pour vérifier que la GPO "Audit Credential Validation is set to Success and Failure" est appliquée
PS C:\WINDOWS\system32> auditpol.exe /get /subcategory:"Credential Validation"
L'erreur 0x00000057 s'est produite :
Paramètre incorrect.

Utilisation : Commande AuditPol [<sous-commande><options>]

Commandes (une seule commande autorisée par exécution)
/? Aide (contextuelle)
/get Affiche la stratégie d'audit actuelle.
/set Définit la stratégie d'audit.
/list Affiche les éléments de stratégie sélectionnables.
/backup Enregistre une stratégie d'audit dans un fichier.
/restore Restaure une stratégie d'audit à partir d'un fichier.
/clear Efface une stratégie d'audit.
/remove Supprime une stratégie d'audit par utilisateur pour un compte d'utilisateur.
/resourceSACL Configure les listes SACL de ressource globale.

Utilisez AuditPol <commande> /? pour obtenir des détails sur chaque commande
```

FIGURE 26 – Rapport d'application des GPO sur le poste HP026

L'exécution de cette commande a révélé plusieurs difonctionnements :

- Le nom de la GPO à vérifier n'était pas correctement écrit, il fallait soit appeler la GPO par son GUID soit par son nom exact dans la langue du système d'exploitation, dans notre cas, le nom de la GPO était "Validation des informations d'identification" au lieu de "Credential Validation"
- Le retour de la commande n'était pas correctement traité, le module SCA attendait le retour "Success and Failure" alors que la commande retournait "Succès et échec" à cause de la langue du système d'exploitation.

2.4.6.2 Solution

Afin de remédier à ce problème, il a été décidé de modifier les commandes utilisées par le module afin d'inclure le GUID à la place du nom anglais ainsi que les résultats attendus en utilisant le résultat en français pour ce dernier. Cette modification a été réalisé sur l'ensemble du fichier lorsqu'une commande était utilisée pour vérifier l'application d'une GPO.

L'utilisation des accents dans la langue française a elle posé un autre souci, en effet l'agent Wazuh exécutent les commandes via PowerShell en tant qu'agisseuse système, ce qui limite le sup-

port UTF-8 natif. Pour contourner ce problème, nous avons encapsulé la commande `auditpol` dans une commande PowerShell avec l'encodage UTF-8, permettant ainsi d'utiliser directement les caractères accentués comme "Succès et échec". La commande suivante a été implémentée :

```
PS C:\WINDOWS\system32> "c:\powershell -Command \"auditpol /get /subcategory:'{0CCE923F-69AE-11D9-BED3-505054503030}'\" -match 'Succès et échec') { echo 'PASS' } else { echo 'FAIL' }\" -> r:PASS"
```

FIGURE 27 – Commande PowerShell modifiée pour supporter les accents

Une fois ce problème réglé, nous avons eu besoin de déployer le nouveau fichier de test sur l'ensemble des postes afin de recalculer le taux de conformité, initialement, nous pensions que remplacer le fichier sur le serveur Wazuh Manager sous `/var/ossec/test/sca` et le supprimer des postes suffirait, cependant, après plusieurs tests, nous avons constaté que les agents ne récupéraient pas automatiquement le nouveau fichier de test.

Nous avons donc décidé de déployer le nouveau fichier sur les machines du parc via GPO, pour cela :

—

[présenter la GPO de déploiement du fichier de test SCA sur les postes]

2.4.7 Conclusion de la mission et critiques

2.4.7.1 Axe d'amélioration possible - BloodHound

BloodHound est un outil utilisé en Blue Team ou en Red Team, il permet d'analyser de la sécurité des réseaux Active Directory en représentant sous la forme de graphes les relations entre les utilisateurs, les groupes, les ordinateurs ainsi que les permissions au sein d'un domaine. En utilisant BloodHound, il est possible d'identifier les chemins d'attaque potentiels, les comptes à privilèges élevés et les vulnérabilités dans la configuration de l'Active Directory.

L'utilisation de BloodHound pourrait être un axe d'amélioration afin de renforcer davantage la sécurité de l'Active Directory en identifiant les chemins d'attaque potentiels et en mettant en place des mesures pour les atténuer. Par exemple, BloodHound pourrait révéler des comptes avec des permissions excessives ou des relations d'accès non sécurisées, permettant ainsi de les corriger avant qu'elles ne soient exploitées par des attaquants.

[inclure un exemple]

2.5 Création et implémentation d'une stratégie de sauvegarde

2.6 Entretien du parc informatique et missions annexes

à ajouter en fonction de ce que je veux développer.

1. debug du problème de synchronisation de l'Active Directory
2. debug du problème de synchronisation de mail
3. Diagnostic d'un problème de connexion au serveur nas
4. installation de suricata
5. configuration d'un réseau wifi invité

3 Impact environnemental et sociétal

3.1 Impact de mes déplacements au long de mon alternance

3.1.1 Déplacements quotidiens

Dans le cadre de mon alternance, j'effectuais un trajet domicile-travail aller-retour chaque jour ouvré. Les émissions de CO₂ ont été estimées à l'aide du calculateur de l'ADEME.

Le trajet quotidien se décompose comme suit :

- **Tramway** : 1,5 km, soit 0,03 g CO₂e/km ;
- **TER Grenoble – Moirans** : 19 km, soit 0,17 g CO₂e/km ;
- **Marche à pied jusqu'au bureau** : 1,1 km, impact négligeable.

L'ensemble du trajet représente environ 3,68 g de CO₂e par déplacement, soit 7,36 g de CO₂e par journée de travail.

Sur une période estimée à 30 semaines d'alternance à raison de 5 jours par semaine, les déplacements domicile-travail représentent environ 1,1 kg de CO₂e émis.

3.1.2 Déplacements ponctuels

Au cours de mon alternance, j'ai été amené à effectuer plusieurs déplacements professionnels, notamment vers le site de Nerys à Gardanne (Bouches-du-Rhône).

Ce trajet a été réalisé en covoiturage à trois personnes à bord d'un véhicule hybride de type SUV. La distance parcourue était d'environ 294 km pour un aller simple, soit 588 km aller-retour.

D'après les estimations réalisées à l'aide du calculateur de l'ADEME, ce déplacement représente environ 11,9 kg de CO₂e pour l'aller-retour.

Bien que cette valeur soit significativement supérieure aux émissions générées par mes trajets quotidiens, ce type de déplacement est resté exceptionnel durant la période d'alternance.

3.2 Actions écologiques et sociales des actions menées par l'entreprise

3.3 Impacts sociétaux des projets réalisés

4 Bilan personnel

[justification de AC 33.1 et 33.03 du PN + AC 36.1 +36.03]

Cette alternance m'a permis de consolider et d'approfondir des compétences techniques en administration système, cybersécurité opérationnelle et développement, tout en les appliquant dans un contexte industriel réel et exigeant. Les missions confiées m'ont confronté à des problématiques concrètes de sécurisation du système d'information, de conformité réglementaire et de maintien en condition opérationnelle, dépassant largement le cadre théorique des enseignements. Le travail

autour de l'homologation d'un système d'information « Diffusion Restreinte » a été particulièrement formateur. Il m'a permis de mieux appréhender les enjeux liés à la protection de données sensibles, à la formalisation des procédures de sécurité et à la rigueur nécessaire dans un contexte

soumis à des exigences normatives fortes. Cette mission m'a également sensibilisé à l'importance de la documentation et de la traçabilité dans les démarches de cybersécurité.

Les projets liés au durcissement du système d'information, à la supervision de la sécurité via Wazuh et à la migration de l'Active Directory m'ont permis de développer une vision globale de l'infrastructure et de ses interdépendances. J'ai gagné en capacité d'analyse, en autonomie et en méthode, notamment dans la priorisation des actions de sécurité, l'analyse des vulnérabilités et la mise en œuvre de solutions adaptées aux contraintes de l'entreprise.

Sur le plan humain et organisationnel, cette alternance m'a permis de m'intégrer au sein d'une équipe technique pluridisciplinaire, de participer aux échanges collectifs et de travailler en collaboration avec des profils variés. Les réunions de suivi et le travail en environnement professionnel m'ont aidé à améliorer ma communication technique et à structurer davantage ma démarche de travail.

Cette expérience confirme mon intérêt pour les métiers de l'administration système et de la cybersécurité. Elle m'a permis de mieux définir mon projet professionnel, orienté vers la sécurisation et l'exploitation d'infrastructures informatiques, et constitue une étape déterminante dans la construction de mes compétences et de mon parcours professionnel.

4.0.0.1 Références bibliographiques

Références

- [1] ANSSI, *OASIS — Recommandations pour les architectures des systèmes d'information sensibles ou Diffusion Restreinte*, ANSSI-PG-075 version 1.2, 24/09/2021.
- [2] ANSSI, *Directive II 901-1 — Sécurisation des systèmes d'information sensibles*, Agence nationale de la sécurité des systèmes d'information, version en vigueur, 28/01/2015
- [3] Center for Internet Security (CIS), *CIS Benchmarks*, <https://www.cisecurity.org/cis-benchmarks/>, consulté en 2024.
- [4] Microsoft, *Active Directory Documentation*, <https://docs.microsoft.com/en-us/windows-server/identity/active-directory-domain-services>, consulté en 2024.
- [5] Wazuh, *Wazuh Documentation*, <https://documentation.wazuh.com/>, consulté en 2024.

```

1  --SETUP-01-ModelUpdateEmpty
2
3  UPDATE RAW_DATA
4  SET
5      Model = DLookUp (
6          "[Model]",
7          "RAW_DATA",
8          "UHF100name='" & [UHF100name] & "'" AND [Model] Is Not Null AND
          Trim([Model] & '') <> ''"
9      )
10 WHERE
11     [Model] IS NULL
12     OR Trim([Model] & '') = '';
13
14  --SETUP-02-ModelUpdateUHF100-V2
15
16  UPDATE RAW_DATA
17  SET
18      Model = "UHF100 V2"
19  WHERE
20      [Model] = "UHF100 2 GHz";
21
22  --SETUP-03-ModelNormalise-1
23
24  UPDATE RAW_DATA
25  SET
26      ModelNormalise = IIf(
27          Model = "UHF100",
28          1,
29          IIf(Model = "UHF100 V2", 2, 0)
30      );
31
32  --SETUP-04-ModelNormalise-2
33
34  SELECT DISTINCT
35      SerialNumberNormalise
36  INTO
37      temp_model1_serials
38  FROM
39      RAW_DATA
40  WHERE
41      ModelNormalise = 1;
42
43  --SETUP-05-ModelNormalise-3
44
45  SELECT DISTINCT
46      SerialNumberNormalise
47  INTO
48      temp_model2_serials
49  FROM
50      RAW_DATA
51  WHERE
52      ModelNormalise = 2;
53
54  --SETUP-06-ModelNormalise-4
55
56  UPDATE RAW_DATA
57  SET
58      ModelNormalise = IIf(
59          Year(StartTime) >= 2025, 32
60          2,
61          IIf(
62              Year(StartTime) <= 2020,
63              1,
64              IIf(

```

```

1  --BC-MOD-00-TEST_DATAProd
2
3  SELECT
4      *
5  INTO
6      TEST_DATA_PROD_B1
7  FROM
8      TEST_DATA_REDUIT
9  WHERE
10     Prod = "PROD"
11     AND StationID = "VM_T-D14"
12     AND ModelNormalise = 2;
13
14  --BC-MOD-01-TableEssaisStatuts
15
16  SELECT
17      StartTime,
18      SerialNumberNormalise,
19      ModelNormalise,
20      TotalTime,
21      IIf(UUTresult = "Passed", True, False) AS Passed,
22      IIf(UUTresult = "Failed", True, False) AS Failed,
23      IIf(UUTresult = "Terminated", True, False) AS Terminated,
24      IIf(UUTresult = "Error", True, False) AS Error
25  INTO
26      B1_table_essais_statut
27  FROM
28      TEST_DATA_PROD_B1
29  ORDER BY
30      StartTime;
31
32  --BC-MOD-02-TableFirstPass
33
34  SELECT
35      SerialNumberNormalise,
36      Min(StartTime) AS FirstPassTime
37  INTO
38      B1_table_first_pass
39  FROM
40      B1_table_essais_statut
41  WHERE
42      Passed = True
43  GROUP BY
44      SerialNumberNormalise;
45
46  --BC-MOD-03-TempLastIsError
47
48  SELECT
49      SerialNumberNormalise,
50      Max(StartTime) AS LastTime,
51      Max(IIf(Error = True, 1, 0)) AS LastIsError
52  INTO
53      B1_temp_LastIsError
54  FROM
55      B1_table_essais_statut AS bht1
56  WHERE
57      NOT EXISTS (
58          SELECT
59              1
60          FROM
61              B1_table_first_pass AS bht2
62          WHERE
63              bht2.SerialNumberNormalise = bht1.SerialNumberNormalise
64      )
65  GROUP BY

```

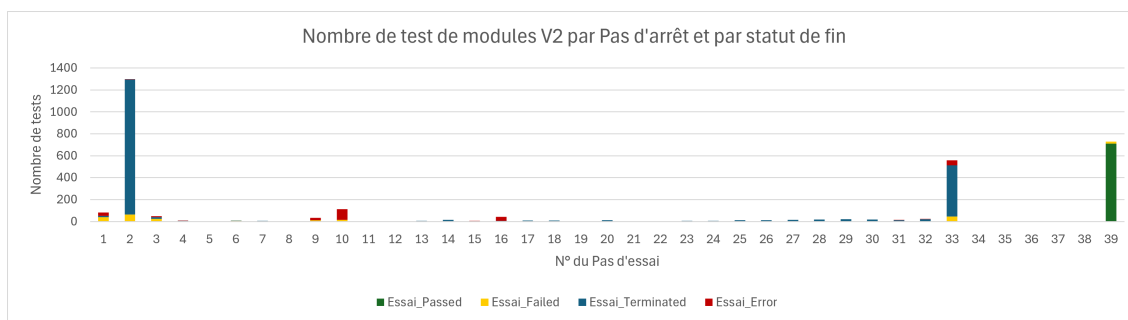
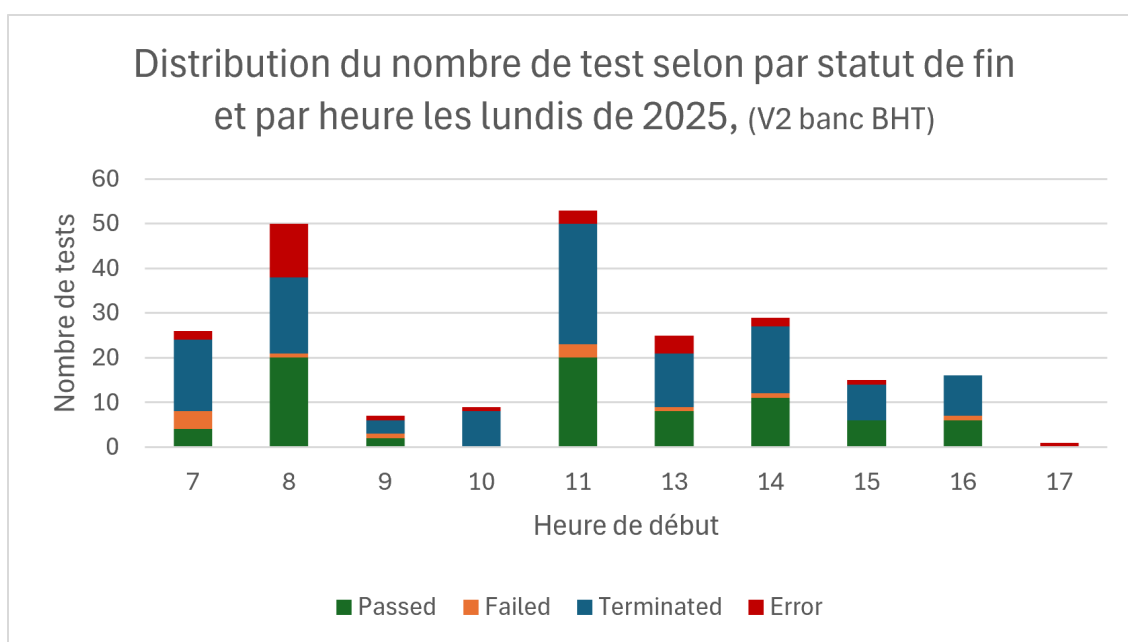
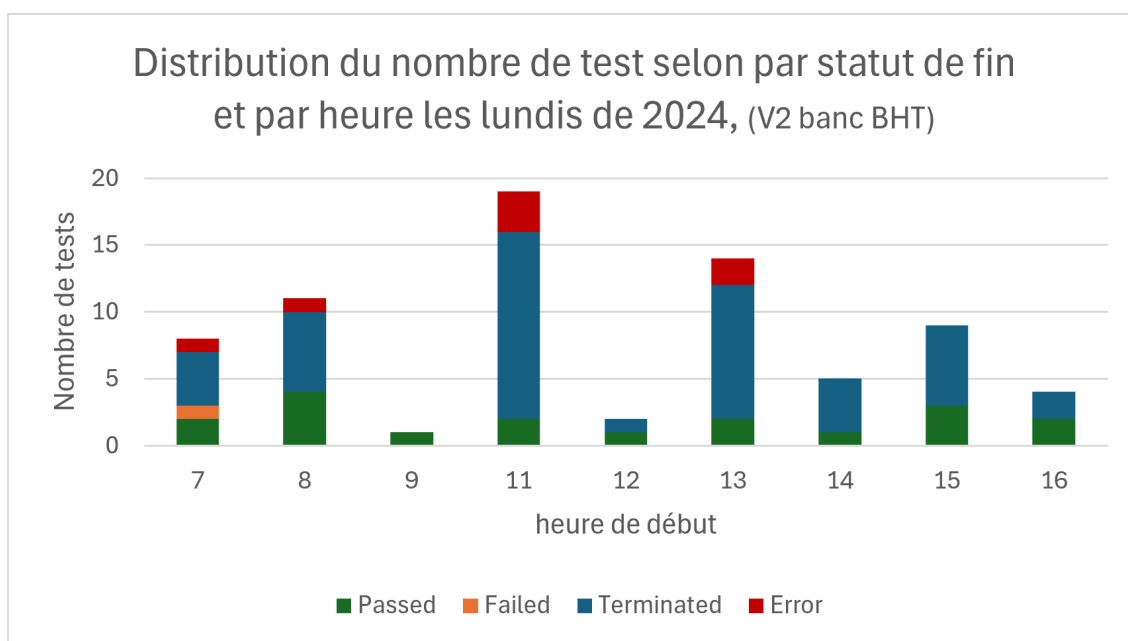
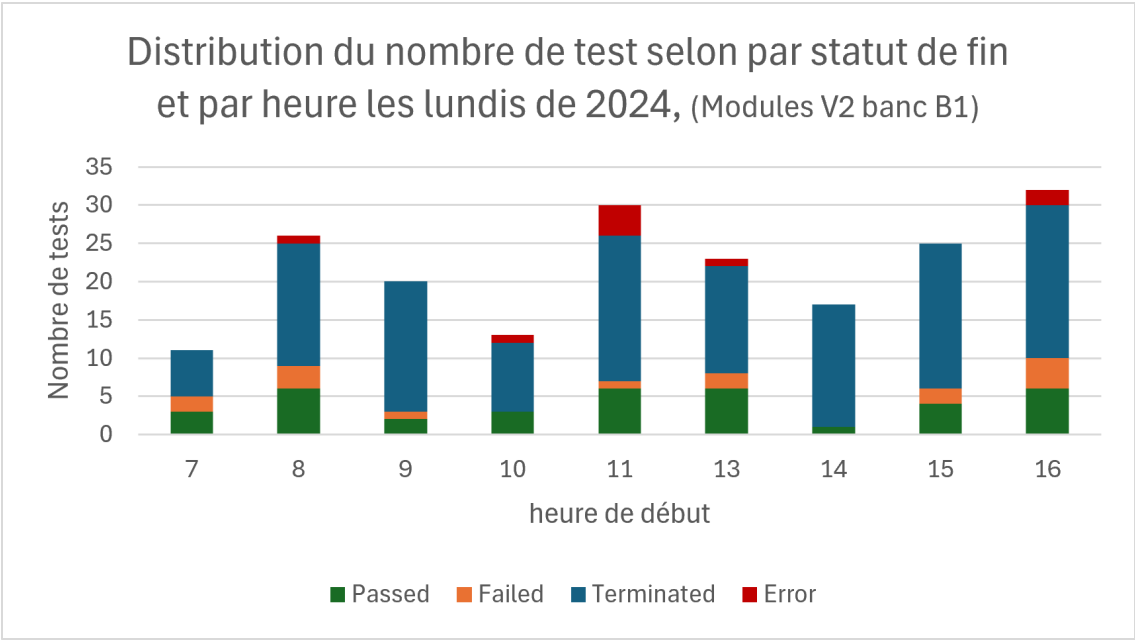
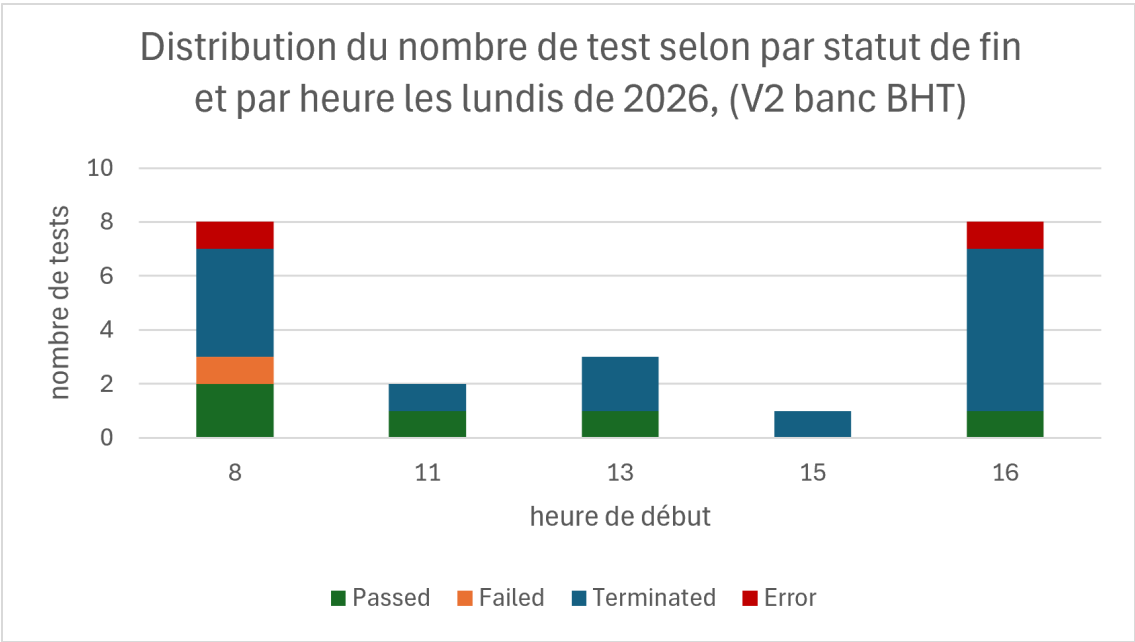
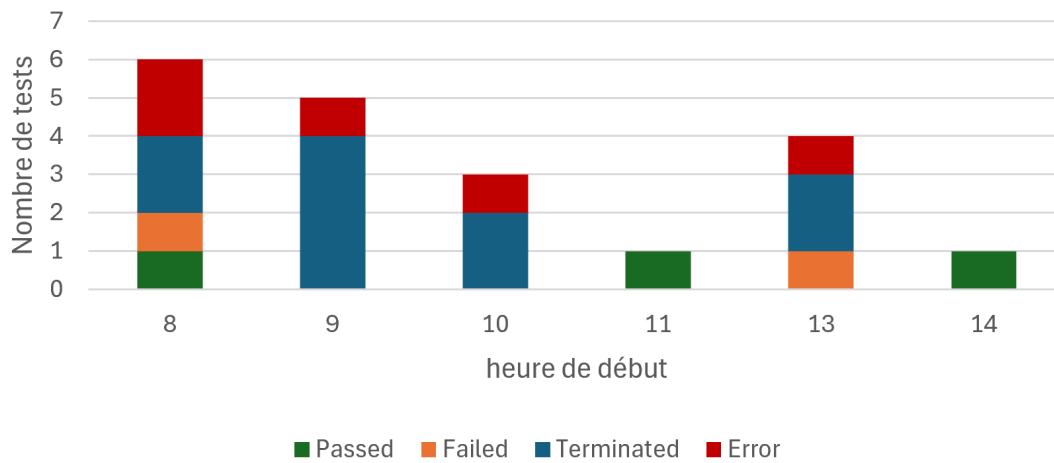


FIGURE 15 – Distribution des statuts de fin des essais par étape de l'essai, modules V2





Distribution du nombre de test selon par statut de fin
et par heure les lundis de 2025, (Modules V2 banc B1)



Distribution du nombre de test selon par statut de fin
et par heure les lundis de 2026, (Modules V2 banc B1)

